TITAI CANONICAL AGENT PLATFORM

Adversarial “Roast My Project” Audit

A repository-grounded, failure-oriented review of architecture, security, durability, tenancy, evidence, interface trust, testing, supply chain, and release integrity.

47 / 100

Strong engineering prototype. Not production-safe yet.

Audit date	10 July 2026
Source	Titai v7 English-only canonical ZIP
Output	v8 roast release candidate
Findings	50 total / 20 project killers
Safe tests	13 suites / 57 tests passed
Static roast	15 of 27 controls passed

This report is deliberately hostile to false confidence. “Fixed” means a narrow mitigation exists; it does not imply independent production verification of the entire domain.

Report Map

01 Executive verdict and finding distribution

02 Audit scorecard

03 Top 20 project killers

04 v8 hardening delivered

05 Complete finding register (F-001 to F-050)

06 Prioritized remediation sequence

07 Validation evidence and honest limitations

08 Release decision

Method

The audit combined repository inspection, negative-space analysis, safe executable gates, dependency vulnerability evidence, architecture and threat modeling, failure-mode analysis, and manual traceability. Each finding contains a severity, status, confidence, evidence target, canonical task mapping, recommendation, and falsifiable acceptance test.

Evidence classes remain separate: documentation, code presence, typecheck, unit tests, integration tests, fault injection, production build, recovery drill, security test, accessibility test, and independent verification are not interchangeable.

Executive Verdict

The project has unusually strong canonical governance and a useful evidence-first interface direction. The roast found that the dominant risk is the mismatch between a sophisticated documented target state and a process-local, globally modeled, partially tested runtime. The highest-leverage work is durable execution, idempotency, tenancy, backup/restore, dependency remediation, and adversarial verification.

Severity	Count	Meaning
Critical	6	Can invalidate security, data integrity, recoverability, or truthful operation.
High	33	Material production risk or major missing control.
Medium	11	Important weakness with narrower blast radius or compensating controls.

Status	Count
Fixed in v8	13
Partially mitigated	5
Open	30
Environment blocked	2

Audit Scorecard

Domain	Score	Roast verdict
Canonical governance and traceability	78/100	Strong documentation and task discipline; implementation status still lags.
Runtime correctness	68/100	Plan and lifecycle hardening improved; durability and concurrency remain unresolved.
Security and capability control	58/100	SSRF, tool defaults, policy mutation, and skill ownership improved; broader sandbox and auth work remains.
Identity, tenancy, and data isolation	31/100	Authentication exists, but the data model is not consistently tenant-scoped.
Durability and disaster recovery	24/100	No durable worker, idempotency layer, or tested backup/restore.
Testing and evidence	52/100	Safe suites and deterministic evaluation pass; DB, E2E, fault, and semantic verification remain thin.
Observability and economics	34/100	Product events exist; no trace/SLO/capacity/cost discipline yet.
Sovereignty and deployment	45/100	Local-first direction is credible; clean offline and production deployment are not proven.
UI and human oversight	64/100	Evidence-first UI is useful; approvals, accessibility, and semantic trust remain incomplete.
Supply chain and release integrity	38/100	English/release gates are good; vulnerabilities, SBOM, provenance, and full build verification remain open.

Scores are an internal audit rubric, not an external benchmark. They are intended to prioritize work and expose false completeness.

Top 20 Project Killers

These findings have the highest potential to invalidate production operation, user trust, or recoverability.

1. F-001 — Detached in-memory execution cannot survive process loss

CRITICAL OPEN

Long-running or side-effecting jobs can disappear, duplicate, or remain permanently inconsistent after deployment, crash, or upgrade.

Required move: Move execution to a durable worker with persisted leases, attempts, checkpoints, cancellation, and resume semantics.

2. F-002 — Side effects lack persisted idempotency and atomic evidence

CRITICAL OPEN

A crash after a side effect but before acknowledgement can repeat irreversible work or create evidence that disagrees with reality.

Required move: Introduce persisted operation keys, effect receipts, transactional outbox records, and compensation rules.

3. F-003 — Deployment model conflicts with globally shared mutable data

CRITICAL PARTIALLY MITIGATED

One user can be affected by another user's global configuration or data; future multi-user deployment risks cross-tenant leakage and confused authority.

Required move: Choose and enforce either explicit single-owner mode or workspace/tenant ownership across every mutable record and query.

4. F-004 — HTTP and provider endpoints allowed server-side request forgery

CRITICAL FIXED IN V8

An agent could probe internal services, cloud metadata, or local control planes.

Required move: Keep destination and redirect validation, DNS resolution checks, and explicit local-model exceptions under policy.

5. F-005 — Invalid or cyclic plans could be reported as completed

CRITICAL FIXED IN V8

A structurally impossible plan could produce a false success signal and misleading evidence.

Required move: Retain preflight plan validation and fail closed when unfinished work has no executable node.

6. F-006 — No tested sovereign backup and restore path

CRITICAL OPEN

Loss or corruption of the SQLite database, keys, artifacts, or model configuration can be unrecoverable.

Required move: Implement export, encrypted backup, version manifest, integrity verification, partial restore, and clean-machine restore drills.

7. F-007 — Drizzle ORM remains on a version with a high-severity advisory

HIGH OPEN

Unsafe identifier construction in affected paths can turn application input into SQL structure rather than data.

Required move: Upgrade Drizzle ORM to a supported non-vulnerable release, regenerate/migrate safely, and execute database integration tests.

8. F-012 — Runs and approvals have no complete wall-clock deadline model

HIGH OPEN

A run can occupy resources indefinitely or remain pending forever after user abandonment.

Required move: Add persisted deadlines, timeout ownership, cancellation propagation, and deterministic terminal states.

9. F-013 — Run event sequence allocation is race-prone

HIGH OPEN

Concurrent writers can duplicate or reorder sequence numbers and break replay evidence.

Required move: Use a transactionally allocated sequence or append-only event table with a unique run/sequence constraint and retry.

10. F-014 — Audit hash-chain append is race-prone and not externally anchored

HIGH OPEN

Concurrent events can fork the chain; a database administrator can rewrite the entire chain and recompute hashes.

Required move: Serialize append, add uniqueness, sign periodic roots, and optionally export roots to independent storage.

11. F-017 — Fetched content remains a prompt-injection channel

HIGH PARTIALLY MITIGATED

A malicious page can attempt to override instructions, induce tool use, or exfiltrate context.

Required move: Separate data from instructions, apply trust labels in the internal protocol, and require policy authorization independent of model text.

12. F-020 — User data export, correction, and deletion are not implemented end-to-end

HIGH OPEN

Users cannot exercise data rights reliably and deleted data may survive in logs, artifacts, or backups.

Required move: Implement data inventory-backed export and deletion workflows with tombstone/backup semantics and audit evidence.

13. F-023 — Registration remains open with weak abuse controls

HIGH OPEN

An exposed installation can be populated by unauthorized users and amplified against local or paid model resources.

Required move: Add explicit registration mode, invitation/first-owner bootstrap, stronger password checks, throttling, and non-enumerating responses.

14. F-025 — Run creation has no client idempotency contract

HIGH OPEN

Network retries or double clicks can duplicate expensive or destructive work.

Required move: Accept scoped idempotency keys, persist request/result hashes, and return the original run for safe retries.

15. F-026 — Approval expiry is not owned by a durable timer

HIGH OPEN

Expired approvals can remain pending or resume ambiguously, blocking work and weakening policy guarantees.

Required move: Persist approval deadlines and let a durable worker own expiry, cancellation, and notification.

16. F-027 — Restart semantics for pending approvals are incomplete

HIGH OPEN

An approved action may never resume or may be reissued incorrectly after restart.

Required move: Model approval as durable workflow state with a persisted continuation and effect ownership.

17. F-038 — No generated SBOM, model inventory, or build provenance

HIGH OPEN

Operators cannot reliably identify vulnerable components, licenses, models, plugins, or reproduce the artifact.

Required move: Generate CycloneDX/SPDX, license inventory, model/plugin hashes, and build provenance during release.

18. F-039 — Observability lacks traces, SLOs, and capacity evidence

HIGH OPEN

Operators cannot answer why work is slow, expensive, failing, or saturating resources.

Required move: Add redacted trace correlation, metrics, usage reconciliation, queue measures, SLOs, and local dashboards.

19. F-042 — Test portfolio is too narrow for the threat and failure model

HIGH OPEN

The system can pass 47 safe tests while remaining unsafe under realistic operation.

Required move: Build layered adversarial and fault-injection suites tied to every high/critical finding.

20. F-047 — SQLite and web-process topology limit safe scale and failover

HIGH OPEN

Multi-process deployment, failover, concurrent writers, and horizontal scaling can corrupt assumptions or lose work.

Required move: Define supported single-node limits, separate durable worker execution, and introduce a tested persistence profile before scaling out.

What v8 Actually Hardened

01. Formal plan validation rejects cycles, self-dependencies, unknown dependencies, duplicate names, and excessive plans.

02. A stalled dependency graph can no longer silently become a successful run.

03. Tool-loop budget exhaustion becomes an explicit failure.

04. Public-network egress and redirects are checked against loopback, private, link-local, metadata, and unsafe DNS results.

05. New agents receive a minimal default tool set rather than every tool.

06. Skill ownership and administrative policy mutation checks were tightened.

07. Provider disabled state and migration failure are enforced.

08. Run concurrency and artifact size received initial bounds.

09. Baseline browser headers were added; CSP remains open.

10. Evidence UI now says “structural coverage,” avoiding a false claim of semantic truth.

11. A repeatable static roast and machine-readable finding registry now ship with the project.

Complete Finding Register

All fifty findings follow. Status is intentionally conservative: open and environment-blocked items remain visible.

F-001 — Detached in-memory execution cannot survive process loss

CRITICAL | OPEN | CONFIDENCE HIGH

Agent runs are launched as process-local asynchronous work. A web process restart can abandon execution and approvals without a durable lease, checkpoint, or resumption contract.

Impact. Long-running or side-effecting jobs can disappear, duplicate, or remain permanently inconsistent after deployment, crash, or upgrade.

Evidence. `src/lib/engine/start.ts`, `src/lib/engine/runner.ts`, `src/lib/db/schema.ts`

Canonical tasks. DUR-001, DUR-002, DUR-003, INF-002

Recommendation. Move execution to a durable worker with persisted leases, attempts, checkpoints, cancellation, and resume semantics.

Acceptance test. Kill the worker at every checkpoint boundary and prove the run resumes exactly once with preserved ownership and evidence.

F-002 — Side effects lack persisted idempotency and atomic evidence

CRITICAL | OPEN | CONFIDENCE HIGH

Tool side effects, run events, and audit records are not bound by a durable idempotency key and single transactional commit protocol.

Impact. A crash after a side effect but before acknowledgement can repeat irreversible work or create evidence that disagrees with reality.

Evidence. `src/lib/engine/runner.ts`, `src/lib/engine/events.ts`, `src/lib/engine/audit.ts`, `src/lib/db/schema.ts`

Canonical tasks. DUR-001, DUR-002, CAP-002

Recommendation. Introduce persisted operation keys, effect receipts, transactional outbox records, and compensation rules.

Acceptance test. Inject a crash after external success but before event commit and prove the retry does not repeat the effect.

F-003 — Deployment model conflicts with globally shared mutable data

CRITICAL | PARTIALLY MITIGATED | CONFIDENCE HIGH

Authentication is multi-user, but policies, templates, and parts of audit/configuration are global rather than tenant-owned. Administrative restrictions reduce some exposure but do not establish a complete tenancy model.

Impact. One user can be affected by another user's global configuration or data; future multi-user deployment risks cross-tenant leakage and confused authority.

Evidence. `src/lib/db/schema.ts`, `src/app/api/policies/route.ts`, `src/app/api/templates/route.ts`, `src/app/api/audit/verify/route.ts`

Canonical tasks. IAM-001, DAT-001

Recommendation. Choose and enforce either explicit single-owner mode or workspace/tenant ownership across every mutable record and query.

Acceptance test. Create two tenants and prove every read, write, audit, template, skill, run, and artifact is isolated under adversarial identifiers.

F-004 — HTTP and provider endpoints allowed server-side request forgery

CRITICAL | FIXED IN V8 | CONFIDENCE HIGH

User-influenced HTTP and provider base URLs previously had no private-network, loopback, metadata, DNS-rebinding, or redirect boundary.

Impact. An agent could probe internal services, cloud metadata, or local control planes.

Evidence. `src/lib/security/egress.ts`, `src/lib/engine/tools/httpFetch.ts`, `src/lib/engine/gateway.ts`, `tests/egress.test.ts`

Canonical tasks. THR-001, CAP-001

Recommendation. Keep destination and redirect validation, DNS resolution checks, and explicit local-model exceptions under policy.

Acceptance test. Run the egress suite against loopback, RFC1918, link-local, metadata, IPv6, encoded addresses, mixed DNS answers, and redirect chains.

F-005 — Invalid or cyclic plans could be reported as completed

CRITICAL | FIXED IN V8 | CONFIDENCE HIGH

The original scheduler could reach no-ready-step state while unfinished nodes remained and still finish the run successfully.

Impact. A structurally impossible plan could produce a false success signal and misleading evidence.

Evidence. `src/lib/engine/plan.ts`, `src/lib/engine/runner.ts`, `tests/plan.test.ts`

Canonical tasks. LIF-001, EVAL-001

Recommendation. Retain preflight plan validation and fail closed when unfinished work has no executable node.

Acceptance test. Test duplicate nodes, unknown edges, self-dependencies, cycles, excessive steps, and runtime deadlock.

F-006 — No tested sovereign backup and restore path

CRITICAL | OPEN | CONFIDENCE HIGH

The repository documents backup goals but contains no implemented, versioned, encrypted, clean-machine restore workflow with drill evidence.

Impact. Loss or corruption of the SQLite database, keys, artifacts, or model configuration can be unrecoverable.

Evidence. `docs/canonical/20_DATA_LIFECYCLE_CONTRACT.md`, `docs/canonical/24_HONEST_LIMITATIONS.md`

Canonical tasks. OPS-001

Recommendation. Implement export, encrypted backup, version manifest, integrity verification, partial restore, and clean-machine restore drills.

Acceptance test. Destroy a disposable instance, restore from the produced archive, and compare users, agents, runs, evidence, artifacts, policies, and hashes.

F-007 — Drizzle ORM remains on a version with a high-severity advisory

HIGH | OPEN | CONFIDENCE HIGH

The current dependency range resolves below the audited fixed line identified by npm audit for identifier-related SQL injection.

Impact. Unsafe identifier construction in affected paths can turn application input into SQL structure rather than data.

Evidence. `package.json`, `docs/roast/evidence/npm-audit.json`

Canonical tasks. SUP-001

Recommendation. Upgrade Drizzle ORM to a supported non-vulnerable release, regenerate/migrate safely, and execute database integration tests.

Acceptance test. npm audit contains no high advisory for Drizzle and all migration/query/integration tests pass on a clean install.

F-008 — Any authenticated user could mutate global policy

HIGH | FIXED IN V8 | CONFIDENCE HIGH

The policy update path previously had an ineffective administrative check while changing system-wide policy.

Impact. A normal user could weaken approval requirements for all users.

Evidence. `src/app/api/policies/route.ts`

Canonical tasks. IAM-001, POL-001

Recommendation. Retain explicit administrative authorization and later tenant-scope policy records.

Acceptance test. A non-admin receives a denial and cannot change persisted policy; an authorized admin creates an attributable audit event.

F-009 — Skill identifiers enabled cross-user prompt access or attachment

HIGH | FIXED IN V8 | CONFIDENCE HIGH

Direct skill fetch and agent skill replacement did not consistently verify ownership.

Impact. A user who guessed an identifier could read or attach another user's procedural prompt material.

Evidence. `src/app/api/skills/[skillId]/route.ts`, `src/app/api/agents/[agentId]/route.ts`

Canonical tasks. IAM-001, SKL-001

Recommendation. Keep owner/built-in checks on both reads and relationship writes.

Acceptance test. Attempt direct reads and attachment with another user's skill identifier and prove denial without existence leakage.

F-010 — New or empty agents inherited every tool

HIGH | FIXED IN V8 | CONFIDENCE HIGH

Agent creation and runtime fallback could translate absent or empty tool configuration into the full registry.

Impact. A minimally configured agent could unexpectedly gain network or write authority.

Evidence. `src/lib/engine/tools/index.ts`, `src/app/api/agents/route.ts`, `src/lib/engine/start.ts`

Canonical tasks. CAP-001, CAP-002

Recommendation. Keep an explicit low-risk default allowlist and treat an empty list as no capabilities.

Acceptance test. Create agents with omitted and empty tool lists; prove only documented tools can execute.

F-011 — Catch-all policy allowed medium-risk actions automatically

HIGH | FIXED IN V8 | CONFIDENCE HIGH

The default policy set included a broad catch-all automatic path that weakened the documented fallback behavior.

Impact. Risky actions could bypass human review despite the UI implying otherwise.

Evidence. `src/lib/engine/policy.ts`, `tests/policy.test.ts`

Canonical tasks. POL-001, UX-001

Recommendation. Keep fail-closed fallback policy and require explicit, narrow auto-approval rules.

Acceptance test. Unknown and medium/high-risk actions resolve to human review or denial in policy tests.

F-012 — Runs and approvals have no complete wall-clock deadline model

HIGH | OPEN | CONFIDENCE HIGH

Iteration limits exist, but total run duration, tool duration, approval deadline, and persisted timeout transitions are incomplete.

Impact. A run can occupy resources indefinitely or remain pending forever after user abandonment.

Evidence. `src/lib/engine/runner.ts`, `src/app/api/approvals/[approvalId]/route.ts`, `src/lib/db/schema.ts`

Canonical tasks. DUR-001, REL-001, PERF-001

Recommendation. Add persisted deadlines, timeout ownership, cancellation propagation, and deterministic terminal states.

Acceptance test. Advance a fake clock across model, tool, approval, and run deadlines and prove exact terminal events and released leases.

F-013 — Run event sequence allocation is race-prone

HIGH | OPEN | CONFIDENCE HIGH

Event sequence numbers are derived from the current maximum without a database uniqueness/serialization strategy proven under concurrency.

Impact. Concurrent writers can duplicate or reorder sequence numbers and break replay evidence.

Evidence. `src/lib/engine/events.ts`, `src/lib/db/schema.ts`

Canonical tasks. DUR-002, OBS-001

Recommendation. Use a transactionally allocated sequence or append-only event table with a unique run/sequence constraint and retry.

Acceptance test. Run concurrent appenders and prove contiguous unique ordering under load and injected transaction retries.

F-014 — Audit hash-chain append is race-prone and not externally anchored

HIGH | OPEN | CONFIDENCE HIGH

The next audit hash depends on the latest row without a serialized append protocol, and no external checkpoint proves later database history was not rewritten.

Impact. Concurrent events can fork the chain; a database administrator can rewrite the entire chain and recompute hashes.

Evidence. `src/lib/engine/audit.ts`, `scripts/verify-audit.ts`, `src/lib/db/schema.ts`

Canonical tasks. OBS-001, SEC-002

Recommendation. Serialize append, add uniqueness, sign periodic roots, and optionally export roots to independent storage.

Acceptance test. Generate concurrent audit writes, verify one linear chain, then mutate history and prove signed-root verification fails.

F-015 — Disabled provider configurations were still eligible

HIGH | FIXED IN V8 | CONFIDENCE HIGH

Provider activation status was not consistently enforced during dispatch or provider tests.

Impact. An operator could believe a provider was disabled while the system still sent data to it.

Evidence. `src/lib/engine/gateway.ts`, `src/lib/engine/runner.ts`, `src/app/api/providers/test/route.ts`

Canonical tasks. PROV-001, PROV-002

Recommendation. Retain enabled checks at every provider resolution boundary.

Acceptance test. Disable each provider and prove dispatch, health test, and fallback routing never contact it.

F-016 — Database migration failure was tolerated

HIGH | FIXED IN V8 | CONFIDENCE HIGH

Migration errors were logged but startup could continue against an unknown schema.

Impact. The application could write incompatible data or fail later in less diagnosable ways.

Evidence. `src/lib/db/index.ts`

Canonical tasks. OPS-001, INF-001

Recommendation. Keep startup fail-closed for required schema migrations.

Acceptance test. Force a migration failure and prove the process refuses readiness without serving mutation routes.

F-017 — Fetched content remains a prompt-injection channel

HIGH | PARTIALLY MITIGATED | CONFIDENCE HIGH

Fetched data is now labeled untrusted and egress-limited, but untrusted text still enters model context without a fully enforced authority separation or content transformation policy.

Impact. A malicious page can attempt to override instructions, induce tool use, or exfiltrate context.

Evidence. `src/lib/engine/tools/httpFetch.ts`, `src/lib/engine/runner.ts`, `docs/canonical/07_SECURITY_TRUST_SAFETY.md`

Canonical tasks. CAP-001, CAP-002, THR-001

Recommendation. Separate data from instructions, apply trust labels in the internal protocol, and require policy authorization independent of model text.

Acceptance test. Use adversarial fetched pages that request secrets and destructive tools; prove zero authority escalation and no protected-context leakage.

F-018 — Native database integration tests cannot run in the constrained environment

HIGH | ENVIRONMENT BLOCKED | CONFIDENCE HIGH

The safe install deliberately skips native post-install scripts, leaving better-sqlite3 unavailable for three database-backed suites.

Impact. Critical approval expiry, audit, and runner integration behavior is not independently executed in this environment.

Evidence. `docs/roast/evidence/v8-full-tests.txt`, `docs/canonical/24_HONEST_LIMITATIONS.md`

Canonical tasks. EVAL-002

Recommendation. Run the blocked suites on an approved clean Linux CI image with pinned Node headers and a trusted prebuilt/native toolchain.

Acceptance test. All database suites pass from a clean lockfile install and publish logs, environment digest, and database reset evidence.

F-019 — Production build did not complete end-to-end in the audit environment

HIGH | ENVIRONMENT BLOCKED | CONFIDENCE HIGH

Next.js compilation completed, but the process stalled during later build work and was stopped to avoid another long-running lockup.

Impact. Deployability, static generation, and runtime route compatibility are not fully proven for this release candidate.

Evidence. `docs/roast/evidence/build.txt`, `docs/canonical/24_HONEST_LIMITATIONS.md`

Canonical tasks. EVAL-002, INF-001

Recommendation. Run a clean production build with bounded diagnostics in CI, archive build logs, then execute startup and Playwright smoke tests.

Acceptance test. A clean build exits zero, the production server reaches readiness, and critical UI/API flows pass.

F-020 — User data export, correction, and deletion are not implemented end-to-end

HIGH | OPEN | CONFIDENCE HIGH

A lifecycle contract exists, but the application does not demonstrate complete export, correction, deletion, derived-data cleanup, and backup propagation.

Impact. Users cannot exercise data rights reliably and deleted data may survive in logs, artifacts, or backups.

Evidence. `docs/canonical/20_DATA_LIFECYCLE_CONTRACT.md`, `src/lib/db/schema.ts`

Canonical tasks. DAT-001, OPS-001, MEM-001

Recommendation. Implement data inventory-backed export and deletion workflows with tombstone/backup semantics and audit evidence.

Acceptance test. Create a user with all data classes, export it, delete it, search every primary/derived store, restore an older backup, and prove policy-compliant handling.

F-021 — Custom templates are globally visible and mutable

HIGH | OPEN | CONFIDENCE HIGH

Template records do not carry owner or tenant identity even though users authenticate separately.

Impact. Private workflows or proprietary prompts can be exposed or changed across users.

Evidence. `src/lib/db/schema.ts`, `src/app/api/templates/route.ts`

Canonical tasks. IAM-001

Recommendation. Separate immutable built-ins from tenant-owned custom templates and scope every query.

Acceptance test. Two-user route tests prove private templates cannot be listed, read, updated, or referenced cross-tenant.

F-022 — Audit access is restricted but audit data remains globally modeled

HIGH | PARTIALLY MITIGATED | CONFIDENCE HIGH

The route now restricts entries to administrators, but audit rows lack a complete tenant/workspace ownership model and delegated audit roles.

Impact. A global administrator becomes a high-value data aggregation point and tenant-level audit cannot be safely delegated.

Evidence. `src/app/api/audit/verify/route.ts`, `src/lib/db/schema.ts`

Canonical tasks. IAM-001, OBS-001

Recommendation. Add tenant/workspace dimensions and explicit audit-reader roles while preserving system-level security audit separation.

Acceptance test. Tenant auditors see only their workspace; system auditors see redacted cross-tenant metadata under separate authorization.

F-023 — Registration remains open with weak abuse controls

HIGH | OPEN | CONFIDENCE HIGH

The registration route accepts public account creation with a low password threshold and lacks invite/closed/first-owner deployment modes.

Impact. An exposed installation can be populated by unauthorized users and amplified against local or paid model resources.

Evidence. `src/app/api/register/route.ts`, `src/lib/auth/password.ts`

Canonical tasks. IAM-001, SEC-002

Recommendation. Add explicit registration mode, invitation/first-owner bootstrap, stronger password checks, throttling, and non-enumerating responses.

Acceptance test. Unauthenticated registration is denied in closed mode; invite reuse, enumeration, weak passwords, and burst attempts fail safely.

F-024 — Secret encryption lacks documented rotation and context binding

HIGH | OPEN | CONFIDENCE MEDIUM

Provider credentials are encrypted, but key versioning, rotation, associated-data binding, custody, backup recovery, and revocation are incomplete.

Impact. A leaked master key or ciphertext relocation can expose all provider credentials with limited recovery options.

Evidence. `src/lib/crypto.ts`, `docs/canonical/07_SECURITY_TRUST_SAFETY.md`

Canonical tasks. SEC-002

Recommendation. Introduce key IDs, rotation, AEAD associated data, scoped decrypt authority, secure backup handling, and revocation drills.

Acceptance test. Rotate from key A to B without downtime, prove old ciphertext migration, reject swapped record context, and restore credentials securely.

F-025 — Run creation has no client idempotency contract

HIGH | OPEN | CONFIDENCE HIGH

Repeated POST requests can create separate runs because the API does not accept and persist a caller idempotency key.

Impact. Network retries or double clicks can duplicate expensive or destructive work.

Evidence. `src/app/api/runs/route.ts`, `src/lib/db/schema.ts`

Canonical tasks. DUR-002

Recommendation. Accept scoped idempotency keys, persist request/result hashes, and return the original run for safe retries.

Acceptance test. Send the same request concurrently and repeatedly; prove exactly one run and a deterministic replay response.

F-026 — Approval expiry is not owned by a durable timer

HIGH | OPEN | CONFIDENCE HIGH

Pending approvals rely on process-local coordination and do not demonstrate a persisted scheduler that enforces deadline transitions after restart.

Impact. Expired approvals can remain pending or resume ambiguously, blocking work and weakening policy guarantees.

Evidence. `src/lib/engine/runner.ts`, `src/app/api/approvals/[approvalId]/route.ts`, `tests/approval-expiry.test.ts`

Canonical tasks. DUR-003, UX-001

Recommendation. Persist approval deadlines and let a durable worker own expiry, cancellation, and notification.

Acceptance test. Restart before and after expiry and prove one deterministic expired transition and no later execution.

F-027 — Restart semantics for pending approvals are incomplete

HIGH | OPEN | CONFIDENCE HIGH

The process-local promise that resumes a run after approval cannot be reconstructed from the database alone.

Impact. An approved action may never resume or may be reissued incorrectly after restart.

Evidence. `src/lib/engine/runner.ts`, `src/lib/db/schema.ts`

Canonical tasks. DUR-003

Recommendation. Model approval as durable workflow state with a persisted continuation and effect ownership.

Acceptance test. Restart with a pending approval, decide it from another process, and prove the exact continuation resumes once.

F-028 — Configured maximum plan size was not enforced

HIGH | FIXED IN V8 | CONFIDENCE HIGH

The planner schema previously accepted plans beyond the configured step limit.

Impact. A model could create runaway work graphs and consume disproportionate resources.

Evidence. `src/lib/engine/plan.ts`, `tests/plan.test.ts`

Canonical tasks. LIF-001, PERF-001

Recommendation. Keep max-step enforcement at parse/validation time.

Acceptance test. Generate plans at limit, limit+1, and extreme sizes; prove bounded parse time and clear rejection.

F-029 — Tool iteration exhaustion could be treated as success

HIGH | FIXED IN V8 | CONFIDENCE HIGH

A step could leave the model still requesting tools after the loop budget but continue toward completion.

Impact. Incomplete or looping work could be presented as successful.

Evidence. `src/lib/engine/runner.ts`

Canonical tasks. LIF-001, EVAL-002

Recommendation. Fail the step and run with explicit budget-exhausted evidence.

Acceptance test. Use a model fixture that always requests another tool and prove deterministic failure at the configured limit.

F-030 — Usage accounting could double-count tokens

MEDIUM | FIXED IN V8 | CONFIDENCE HIGH

Token usage could be recorded both through provider events and response usage aggregation.

Impact. Cost, capacity, and model-routing decisions could be based on inflated telemetry.

Evidence. `src/lib/engine/runner.ts`, `src/lib/engine/event-types.ts`

Canonical tasks. OBS-001, PERF-001

Recommendation. Use one authoritative accounting path with reconciliation fields.

Acceptance test. Replay a response with provider usage events and summary usage; prove totals equal the provider bill once.

F-031 — Rejected approval did not close the tool evidence chain

MEDIUM | FIXED IN V8 | CONFIDENCE HIGH

A rejected action produced a model-facing result but no matching tool.result event.

Impact. Evidence reconstruction reported an unmatched call and could not explain the human decision path.

Evidence. `src/lib/engine/runner.ts`, `src/lib/engine/evidence-summary.ts`

Canonical tasks. UX-002, OBS-001

Recommendation. Emit a terminal tool result representing rejection without executing the tool.

Acceptance test. Reject an approval and prove call/result pairing, no side effect, and visible human-decision evidence.

F-032 — Prompts and objectives are duplicated into persistent evidence without minimization

MEDIUM | OPEN | CONFIDENCE HIGH

Run-start and audit records include rich system prompt or objective material that may contain confidential context.

Impact. Sensitive business data can persist longer and in more stores than users expect.

Evidence. `src/lib/engine/runner.ts`, `src/lib/engine/audit.ts`, `src/lib/engine/events.ts`

Canonical tasks. DAT-001, OBS-001

Recommendation. Store references/hashes and redacted summaries by default; define an explicit secure evidence retention mode for full content.

Acceptance test. Insert known sensitive markers and prove default logs/events/audit omit them while authorized artifact storage remains traceable.

F-033 — Artifact writes had no practical size ceiling

MEDIUM | FIXED IN V8 | CONFIDENCE HIGH

The write-artifact tool accepted unbounded content.

Impact. A model could exhaust memory, disk, database capacity, or UI rendering.

Evidence. `src/lib/engine/tools/writeArtifact.ts`

Canonical tasks. CAP-002, PERF-001

Recommendation. Keep a documented byte cap and later add streaming/object storage where justified.

Acceptance test. Attempt boundary, boundary+1, and multibyte payloads and prove exact size enforcement.

F-034 — Policy regular expressions can create denial of service

MEDIUM | OPEN | CONFIDENCE MEDIUM

User-configurable or broad regular expressions are evaluated without a safe-regex restriction or execution budget.

Impact. Catastrophic backtracking can block the Node.js event loop during authorization.

Evidence. `src/lib/engine/policy.ts`, `src/app/api/policies/route.ts`

Canonical tasks. POL-001, SEC-002

Recommendation. Use constrained glob/pattern semantics or safe-regex validation and bounded evaluation.

Acceptance test. Submit known pathological expressions and long inputs; prove bounded latency or rejection.

F-035 — Rate limiting is process-local and trusts client forwarding headers

MEDIUM | OPEN | CONFIDENCE HIGH

The limiter is memory-resident and derives identity from a spoofable forwarding header without trusted-proxy configuration.

Impact. Attackers can bypass limits across workers/restarts or by rotating forged header values.

Evidence. `src/lib/rate-limit.ts`, `src/app/api/runs/route.ts`, `src/app/api/providers/test/route.ts`

Canonical tasks. IAM-001, INF-002

Recommendation. Use authenticated principal/workspace keys and a shared limiter or documented single-process boundary; configure trusted proxies explicitly.

Acceptance test. Exercise multiple workers, restarts, spoofed headers, users, and IPs; prove the intended global and per-user budget.

F-036 — Security headers improved but CSP remains absent

MEDIUM | PARTIALLY MITIGATED | CONFIDENCE HIGH

The release now adds baseline headers but does not define a tested Content Security Policy.

Impact. A future injection bug has fewer browser-side containment barriers.

Evidence. `next.config.ts`

Canonical tasks. THR-001

Recommendation. Add nonce/hash-based CSP, report-only rollout, and route tests without breaking Next.js runtime behavior.

Acceptance test. Production responses include the approved CSP and Playwright confirms no required script/style violations.

F-037 — Source lint is intentionally shallow and build ignores ESLint

MEDIUM | OPEN | CONFIDENCE HIGH

The custom source scanner catches a narrow set of hazards, while Next.js is configured to ignore ESLint during builds and ESLint is not a complete release gate.

Impact. Common correctness, React, security, and accessibility defects can pass CI.

Evidence. `scripts/lint-source.mjs`, `next.config.ts`, `package.json`

Canonical tasks. EVAL-002, SUP-001

Recommendation. Adopt a pinned non-interactive ESLint configuration plus targeted security/accessibility rules and keep the fast scanner as an additional gate.

Acceptance test. A clean install runs lint non-interactively; seeded violations fail with stable diagnostics.

F-038 — No generated SBOM, model inventory, or build provenance

HIGH | OPEN | CONFIDENCE HIGH

The project has dependency documentation but no machine-generated release bill of materials or attestations in the archive.

Impact. Operators cannot reliably identify vulnerable components, licenses, models, plugins, or reproduce the artifact.

Evidence. `package.json`, `docs/canonical/14_ACCEPTANCE_GATES.md`

Canonical tasks. SUP-001, MOD-001

Recommendation. Generate CycloneDX/SPDX, license inventory, model/plugin hashes, and build provenance during release.

Acceptance test. The extracted ZIP contains validated inventories matching the lockfile and shipped artifacts, signed or hashed in the release manifest.

F-039 — Observability lacks traces, SLOs, and capacity evidence

HIGH | OPEN | CONFIDENCE HIGH

Events exist for product behavior, but there is no implemented OpenTelemetry-compatible trace model, SLO dashboard, error budget, or measured queue/capacity model.

Impact. Operators cannot answer why work is slow, expensive, failing, or saturating resources.

Evidence. `src/lib/engine/event-types.ts`, `docs/canonical/09_EVALUATION_OBSERVABILITY.md`

Canonical tasks. OBS-001, OBS-002, PERF-001

Recommendation. Add redacted trace correlation, metrics, usage reconciliation, queue measures, SLOs, and local dashboards.

Acceptance test. A benchmark run yields traceable p50/p95/p99 latency, queue depth, failure classes, token/cost totals, and an SLO verdict.

F-040 — Governed memory architecture is documentation-only

HIGH | OPEN | CONFIDENCE HIGH

The platform does not implement provenance-aware working, episodic, semantic, decision, preference, and negative memory with correction/deletion controls.

Impact. Long-running agents either forget important context or accumulate untrusted, stale, contradictory, or cross-user material.

Evidence. `docs/canonical/06_DATA_MEMORY_KNOWLEDGE.md`, `src/lib/db/schema.ts`

Canonical tasks. MEM-001, MEM-002, MEM-003

Recommendation. Implement the smallest local governed memory slice before adding a vector database.

Acceptance test. Create contradictory, expired, private, corrected, and deleted memories; prove scoring, provenance, isolation, and removal behavior.

F-041 — Provider selection is not a measured capability router

HIGH | OPEN | CONFIDENCE HIGH

Provider adapters exist, but there is no model registry with measured capabilities, policy constraints, quality/cost/latency/energy scores, or explicit no-eligible-model outcome.

Impact. Critical work can be dispatched by static configuration rather than demonstrated fitness.

Evidence. `src/lib/engine/gateway.ts`, `src/lib/engine/providers`, `docs/canonical/05_REASONING_AND_INTELLIGENCE.md`

Canonical tasks. MOD-001, PROV-001, PROV-002

Recommendation. Create a versioned model registry and evaluation-backed multi-objective router with explainable fallback.

Acceptance test. Given constrained tasks and unavailable models, route to the Pareto-eligible candidate or return no-eligible-model without silent downgrade.

F-042 — Test portfolio is too narrow for the threat and failure model

HIGH | OPEN | CONFIDENCE HIGH

Unit coverage improved, but route authorization, tenancy, crash recovery, concurrency, fault injection, accessibility, visual regression, offline startup, and restoration are not comprehensively tested.

Impact. The system can pass 47 safe tests while remaining unsafe under realistic operation.

Evidence. `tests`, `e2e`, `docs/canonical/14_ACCEPTANCE_GATES.md`

Canonical tasks. EVAL-002, REL-001

Recommendation. Build layered adversarial and fault-injection suites tied to every high/critical finding.

Acceptance test. Each high/critical finding has a failing regression before repair and a passing independent verification after repair.

F-043 — End-to-end tests are brittle smoke checks

MEDIUM | OPEN | CONFIDENCE HIGH

The small Playwright suite relies on demo credentials and fixed waits rather than isolated fixtures, semantic readiness, and security assertions.

Impact. Tests can flake, pass against stale state, or miss authorization and recovery failures.

Evidence. `e2e`, `playwright.config.ts`

Canonical tasks. EVAL-002, UX-001

Recommendation. Use isolated test users/databases, deterministic fixtures, event-based waits, and security/accessibility assertions.

Acceptance test. Run E2E repeatedly in parallel and serial modes with zero shared-state dependence and bounded flake rate.

F-044 — Seed workflow is destructive and includes known demo credentials

MEDIUM | OPEN | CONFIDENCE HIGH

The seed path resets shared state and provisions predictable accounts for demonstration.

Impact. Running it in the wrong environment can destroy data or create an easily guessed account.

Evidence. `scripts/seed.ts`, `playwright.config.ts`

Canonical tasks. OPS-001, SEC-002

Recommendation. Require explicit development/test environment, random ephemeral credentials, targeted fixture cleanup, and destructive confirmation guards.

Acceptance test. Attempt seed in production mode and against a non-empty protected database; prove hard refusal and no mutation.

F-045 — Evidence percentage measures structure, not truth

MEDIUM | PARTIALLY MITIGATED | CONFIDENCE HIGH

The UI originally risked presenting event-shape completeness as overall evidence quality. It is now labeled structural coverage, but semantic correctness and verifier independence remain separate unfinished controls.

Impact. Users can over-trust a complete-looking ledger even when outputs are wrong or self-verified.

Evidence. `src/components/runs/evidence-ledger.tsx`, `src/lib/engine/evidence-summary.ts`

Canonical tasks. UX-002, EVAL-002

Recommendation. Keep structural labeling and add claim-level evidence, verifier identity, reproducibility, contradiction, and semantic evaluation.

Acceptance test. Show a structurally complete but deliberately false run and prove the UI does not label it verified.

F-046 — Most canonical capabilities remain blocked or unimplemented

HIGH | OPEN | CONFIDENCE HIGH

The canonical pack is extensive, but the task graph still marks the majority of production-critical workstreams blocked.

Impact. Documentation volume can be mistaken for platform maturity, obscuring the implementation gap.

Evidence. `docs/canonical/tasks/TASKS.json`, `docs/canonical/16_TRACEABILITY_MATRIX.md`

Canonical tasks. CAN-001

Recommendation. Expose implemented-versus-designed status prominently and execute dependency-unblocking vertical slices rather than adding parallel documents.

Acceptance test. A release dashboard derives status from code/test evidence and cannot count designed-only tasks as delivered capability.

F-047 — SQLite and web-process topology limit safe scale and failover

HIGH OPEN CONFIDENCE HIGH

The control plane, execution loop, and local SQLite database are tightly coupled to one process/filesystem profile.

Impact. Multi-process deployment, failover, concurrent writers, and horizontal scaling can corrupt assumptions or lose work.

Evidence. `src/lib/db/index.ts`, `src/lib/engine/start.ts`, `docs/canonical/08_INFRASTRUCTURE_SOVEREIGNTY.md`

Canonical tasks. INF-001, INF-002, DUR-001

Recommendation. Define supported single-node limits, separate durable worker execution, and introduce a tested persistence profile before scaling out.

Acceptance test. Run load and failover tests at documented limits; unsupported topologies must fail configuration validation.

F-048 — No tested Content Security Policy

HIGH OPEN CONFIDENCE HIGH

The application has baseline browser headers but no CSP, violation reporting, or nonce strategy.

Impact. Cross-site scripting impact is not meaningfully contained at the browser policy layer.

Evidence. `next.config.ts`

Canonical tasks. THR-001

Recommendation. Design and roll out report-only then enforced CSP with route-level automated checks.

Acceptance test. All production pages load under enforced CSP with no unauthorized script, style, frame, connect, image, or font source.

F-049 — Tool arguments are not uniformly governed by explicit versioned schemas

HIGH | OPEN | CONFIDENCE HIGH

Tools expose names and execution code, but the registry does not prove a mandatory schema/contract for every input and output.

Impact. Malformed, oversized, ambiguous, or injected arguments can reach tool implementations inconsistently.

Evidence. `src/lib/engine/tools/index.ts`, `src/lib/engine/types.ts`

Canonical tasks. CAP-001, CAP-002, DEV-001

Recommendation. Require versioned Zod/JSON schemas, byte budgets, normalization, and structured error semantics for every tool.

Acceptance test. Fuzz every tool with invalid types, extra fields, oversized values, Unicode edge cases, and schema-version mismatch.

F-050 — Context and output budgets are incomplete

HIGH | OPEN | CONFIDENCE HIGH

The system bounds some loops and artifacts but lacks an end-to-end context selection budget, output budget, contamination test, and adaptive stopping policy.

Impact. Long histories or retrieved content can crowd out policy/current facts, increase cost, and degrade correctness.

Evidence. `src/lib/engine/runner.ts`, `docs/canonical/05_REASONING_AND_INTELLIGENCE.md`

Canonical tasks. CTX-001, RSN-001, RSN-002

Recommendation. Implement mandatory-context reservation, measured selection, output ceilings, and bounded planner/critic/verifier stopping.

Acceptance test. Run adversarial long-context cases and prove mandatory policy/current code facts survive while cost and latency remain within budget.

Prioritized Remediation Sequence

1	**Stop false durability** Implement durable worker leases, checkpoints, idempotency, and restart-safe approvals.
2	**Choose the ownership model** Commit to single-owner appliance mode or complete workspace tenancy, then migrate every global table and query.
3	**Prove recoverability** Deliver encrypted export, clean-machine restore, corrupted-backup behavior, and measured RTO/RPO.
4	**Close supply-chain blockers** Upgrade vulnerable dependencies; create SBOM, model inventory, license report, and reproducible build evidence.
5	**Turn evidence into truth** Add semantic evaluators, independent verifier identity, adversarial tests, and fault injection.
6	**Add real observability** Implement traces, queue/capacity metrics, SLOs, cost reconciliation, and energy measurement.
7	**Add governed memory last** Implement context and memory only after authority, deletion, tenancy, and provenance boundaries are stable.

Validation Evidence and Honest Limitations

State	Gate	Evidence
PASS	Canonical validation	52 tasks, 48 claims, 28 sources, 19 ADRs, 28 domains, 15 experiments.
PASS	English-only validation	No non-Latin writing-system content found.
PASS	Release audit	Canonical integrity, language policy, exclusions, and credential checks are clean.
PASS	Typecheck	TypeScript completed without errors.
PASS	Safe tests	13 suites and 57 tests passed.
PASS	Baseline evaluation	8 of 8 deterministic cases passed.
OPEN	Static roast	15 of 27 narrow controls passed; 12 remain open.
BLOCKED	Native DB suites	Three suites could not load better-sqlite3 native bindings in constrained mode.
BLOCKED	Production build	Compilation completed, but later Next.js build stages did not finish in the bounded run.
OPEN	Dependency audit	One high and eight moderate advisories recorded at audit time.

Limitations

• This audit does not claim independent production verification of code written during the same work cycle.

• Native SQLite integration, complete production build, and Playwright execution require an approved clean CI environment.

• Static roast checks are regression tripwires, not proofs of runtime security.

• Scores are a transparent internal audit rubric, not an industry benchmark.

• No antivirus, EDR, firewall, or operating-system protection was disabled. No PowerShell or opaque executable workflow was required.

RELEASE DECISION	**Do not deploy v8 as an unattended multi-user production agent platform. Use it as a hardened development/research baseline on a controlled machine while critical findings remain blockers.**

The strongest next move is not another broad document. It is one end-to-end durability and recovery vertical slice with crash injection, exact-once effect evidence, independent verification, and a clean-machine restore.